Alard University Attendance System: Prototype Review

Review of the prototype uploaded on 24 October 2026 (database, README, start script and security architecture image). The backend code was not included, so it has not been reviewed.

Summary

The prototype's structure matches the agreed blueprint well. However, the face data cannot currently tell people apart, which makes the attendance results meaningless. The security document also makes several claims that cannot be supported and should be removed before it goes to Alard.

Critical: the face data cannot tell people apart

All 14 stored face vectors were compared (91 pairs of different people):

- The lowest similarity between any two different people is 0.994, and the average is 0.998.
- The match threshold is 0.60. All 91 pairs are far above it, so in practice any face matches any student.
- The rule that updates a profile only when similarity is above 80% has the same flaw. It passes for everyone, so a stranger's face could slowly rewrite someone else's profile.
- Ten of the 14 vectors are nearly identical to each other. This looks like a placeholder extractor, or the same test image used for every enrolment, rather than a real face model.

The 97% confidence scores in the attendance records therefore mean nothing yet.

Fix: use a real face embedding model (check its commercial licence), re-enroll everyone, and test with real people. A good test is that two different people score well below the threshold.

Claims in the security document that should be removed

The document looks professional, but several statements are false or cannot be backed up. If Alard's IT team or a lawyer checks them, it reflects badly on Amolsoft.

- **"ISO 27001 & DPDP Act 2023 certified", "Certified Secure", "Verified & Approved".** No such certification or approval exists. Use "designed to support DPDP compliance" instead.
- **"Mathematically impossible to reconstruct a face."** Face embeddings can be partly reversed, and research has shown it. Say instead that they are not raw photos and are protected by encryption.
- **"99.4% accuracy over 4 years."** Nothing has measured this, and the data above contradicts it. Remove it until real test results exist.
- **"Zero SQL injection."** Using SQLAlchemy lowers the risk but does not eliminate it.
- **"DPDP compliant."** The database has no consent records and no retention rules yet.
- The image shows empty boxes where emojis failed to render. Fix the fonts before sending it.

Database fixes, in priority order

1. **OTPs are stored in plain text, and `123456` is hard-coded.** Hash the OTPs. Make the fixed dev OTP work only when an environment variable such as `DEV_MODE=true` is set, and never in production.
2. **Face vectors are stored as plain JSON.** Encrypt them at rest, and move to PostgreSQL for production.
3. **There is no real audit log.** The security document promises an "immutable audit trail", but overrides are only columns on `attendance_records`, which can be edited. Add an append-only `audit_logs` table.
4. **There is no `consent_records` table.** It is needed for DPDP compliance, along with a retention setting for class photos. (`photo_path` is empty now, which is good.)
5. **Each user has only one face profile.** If it is ever poisoned, it cannot recover. Keep a trusted baseline plus a few recent templates.
6. **Constraints are missing.** Add `UNIQUE(session_id, student_id)` on attendance records. The data is clean today, but nothing enforces it.
7. **Data inconsistencies.** Confidence is stored as 0.97 for AI marks but 97.1 for manual ones, so pick one scale. One session shows 9 matched but only 8 detected, which is impossible.
8. **Eleven face sessions are active at once.** Add expiry cleanup and a way to revoke sessions on logout.

Risks in the setup

- `start_mac.sh` runs the server with `--host 0.0.0.0`. On a campus Wi-Fi network, anyone could open it and log in as admin with OTP `123456`. Bind to `127.0.0.1` for demos.
- The script runs `seed_data.py` on every start. Check that it does not wipe or duplicate real records on restart.
- The README contains a personal folder path (`/Users/siddharth/...`). Remove it before sharing.
- The pasted React dropdown and sheet components do not fit a "zero React" project. If they belong to a different admin panel, that is fine, but the stacks should not be mixed up.

Next step

Upload the `backend/` folder, especially the face-recognition and auth code, so the cause of the identical vectors can be found.